exchange can be seen as a limited form of *security token service*.

> **DEFINITION** A ***security token service*** (STS) is a service that can translate security tokens from one format to another based on security policies. An STS can be used to bridge security systems that expect different token formats.

When a backend service introspects the exchanged access token, they may see a nested chain of `act` claims, as shown in listing 11.15. As with other access tokens, the `sub` claim indicates the user on whose behalf the request is being made. Access-control decisions should always be made primarily based on the user indicated in this claim. Other claims in the token, such as roles or permissions, will be about that user. The first `act` claim indicates the calling service that is acting on behalf of the user. An `act` claim is itself a JSON claims set that may contain multiple identity attributes about the calling service, such as the issuer of its identity, which may be needed to uniquely identify the service. If the token has passed through multiple services then there may be further `act` claims nested inside the first one, indicating the previous services that also acted as the same user in servicing the same request. If the backend service wants to take the service account into consideration when making access-control decisions, it should limit this to just the first (outermost) `act` identity. Any previous `act` identities are intended only for ensuring a complete audit record.